

VERIFIED ENGINEERING RESULT

# Microsoft Entra CBA with Playwright

Fresh end-to-end verification of certificate-based authentication, private credential retrieval, GitHub workload identity, browser controls, Conditional Access outcomes, privacy, restoration, and cleanup.

PASS

37 / 37

|                      |                                                                  |
|----------------------|------------------------------------------------------------------|
| Result               | PASS - 37 of 37 checks                                           |
| Captured             | 2026-09-22T17:30:36.215Z                                         |
| Public repository    | samitks77/dev-agents-solutions                                   |
| Tested branch        | main                                                             |
| Tested commit        | fb0771dec58a                                                     |
| Credential transport | Key Vault OIDC to process memory; no cloud credential files      |
| Conditional Access   | Positive and negative controls passed; all policy state restored |
| Cleanup              | Evidence artifact, ACI runner, and GitHub runner removed         |

**Customer interpretation:** This report proves the public reference implementation in an isolated lab. It is not evidence from, and makes no claim about, any customer tenant.

## Executive assurance summary

The current main revision completed a new cloud and browser run, regenerated all local controls, executed positive and negative Conditional Access scenarios, restored every changed policy, and then passed an exact 37-check verifier.

### What materially changed

- The runner retrieves the PFX and passphrase from private Key Vault through GitHub OIDC and gives Playwright an in-memory Buffer.
- The cloud flow rejects legacy PFX path/passphrase environment variables and creates no real credential files.
- A schema-v3 receipt attests key-vault-oidc, memory-only transport, and credentialFilesWritten=false.
- The workflow now includes a real synthetic-PFX OpenSSL integration test, preventing regression of the streamed validation path.

### Trust-but-verify controls

|                    |                                                                              |
|--------------------|------------------------------------------------------------------------------|
| Identity           | Exact committed identity values, workflow revision, and proof-set binding    |
| Credential path    | Private DNS + Private Endpoint + OIDC + memory-only PFX handling             |
| Browser            | Headless, headed, wrong-origin, reliability, and session-reuse controls      |
| Conditional Access | MFA positive and SFA negative evidence against the exact lab policy          |
| Restoration        | Lab policy returned to report-only; reviewed managed policies restored       |
| Privacy            | Bounded receipts and completed job log scanned for raw or encoded lab values |
| Cleanup            | Artifact deleted, ACI removed, and GitHub runner deregistered                |

### Evidence boundaries

- No tenant, subscription, user, object, application, or policy identifiers are included.
- No workflow run IDs, sign-in correlation IDs, deployed hostnames, IPs, or CIDRs are included.
- No certificate, private key, token, PFX, or passphrase is included.
- JavaScript buffer overwrite is defense in depth, not a guarantee that every native memory copy is erased.

## Detailed 37-check result

Each row below is projected from the exact fresh proof. Evidence values are intentionally omitted; the check labels and outcomes are sufficient for customer review without exposing the lab.

| Stage                     | Verified control                                                    | Result |
|---------------------------|---------------------------------------------------------------------|--------|
| Cross-gate binding        | Cloud, browser, policy and restoration evidence share one proof set | PASS   |
| GitHub control plane      | Exact workflow run completed successfully                           | PASS   |
| GitHub control plane      | Tested branch and commit are exact                                  | PASS   |
| GitHub control plane      | One exact verification job passed                                   | PASS   |
| GitHub job execution      | Validate the dispatch identifier                                    | PASS   |
| GitHub job execution      | Check out the tested revision                                       | PASS   |
| GitHub job execution      | Verify private Key Vault DNS                                        | PASS   |
| GitHub job execution      | Assert memory-only credential inputs                                | PASS   |
| GitHub job execution      | Validate in-memory credential provider                              | PASS   |
| GitHub job execution      | Type-check the POC                                                  | PASS   |
| GitHub job execution      | Run the headless CBA feasibility test                               | PASS   |
| GitHub job execution      | Validate bounded test evidence                                      | PASS   |
| GitHub job execution      | Upload bounded test evidence                                        | PASS   |
| GitHub job execution      | Verify no credential files were materialized                        | PASS   |
| Public log privacy        | GitHub job log contains no exact or encoded lab deployment values   | PASS   |
| Bounded evidence          | Identity receipt SHA-256 matches the launcher receipt               | PASS   |
| Bounded evidence          | Network receipt SHA-256 matches the launcher receipt                | PASS   |
| Playwright identity       | Exact identity commitment, run, and SHA were verified               | PASS   |
| Local browser controls    | Headed Chromium rendered the exact identity                         | PASS   |
| Local browser controls    | Five independent headless sessions passed                           | PASS   |
| Local browser controls    | Wrong-origin certificate isolation passed                           | PASS   |
| Local browser controls    | Authenticated session reused without a new CBA request              | PASS   |
| Private credential path   | Runner resolved and read Key Vault only at the private IP           | PASS   |
| GitHub workload identity  | OIDC issuer, audience, subject, repository, run, and SHA are exact  | PASS   |
| Ephemeral runner identity | ACI runner name, label, subnet, and operating system are exact      | PASS   |

| Stage                          | Verified control                                                       | Result |
|--------------------------------|------------------------------------------------------------------------|--------|
| Azure control plane            | Azure CLI is on the exact subscription and tenant                      | PASS   |
| Azure private network          | Key Vault public access remains disabled and default action is deny    | PASS   |
| Azure private network          | Key Vault Private Endpoint is succeeded and approved                   | PASS   |
| Azure private network          | Private DNS A record maps the vault to the exact private IP            | PASS   |
| Azure runner network           | Runner subnet remains delegated to ACI and attached to NAT             | PASS   |
| Conditional Access positive    | MFA-classified certificate satisfied the exact lab policy              | PASS   |
| Conditional Access negative    | SFA-classified certificate failed only the exact lab policy            | PASS   |
| Conditional Access restoration | Lab policy is recorded report-only after the proof                     | PASS   |
| Conditional Access restoration | Every temporarily isolated managed policy was restored                 | PASS   |
| Public artifact privacy        | Transient GitHub evidence artifact was deleted after verified download | PASS   |
| Live cleanup                   | Ephemeral ACI container no longer exists                               | PASS   |
| Live cleanup                   | Ephemeral GitHub runner is deregistered                                | PASS   |

## Independent verification and adoption

The implementation is public and can be inspected or rerun in an authorized isolated environment.

**Repository:** [Entra CBA + Playwright reference solution](#)

**Upstream browser pattern:** [Playwright Entra CBA implementation guidance](#)

### Verification tiers

|                         |                                                                           |
|-------------------------|---------------------------------------------------------------------------|
| Tier A - PublicProof    | Static, anonymous verification of published sanitized evidence            |
| Tier B - EvidenceReplay | Authorized read-only replay of retained evidence and live state           |
| Tier C - FreshRun       | New cloud/browser/Conditional Access proof with explicit mutation consent |

### Safe reproduction

From the solution directory, the public tier is available without tenant access:

```
./scripts/Invoke-EntraCbaVerification.ps1 -Tier PublicProof
```

A customer-controlled Tier C run requires its own isolated environment, reviewed policy set, authentication, and explicit tenant-mutation and exclusive Conditional Access maintenance-window consent.

### Evidence commitment

Sanitized JSON SHA-256 commitment: a08d1983b2cbc2c0ab51752b6235a1c3496ec01cc946a38bce75e0ab2c242ecf

Artifact: Entra-CBA-Playwright-Customer-Verification-2026-09-22.json | Tested commit: fb0771dec58abe5fbc4b2c39325f08c8c356a10d

Generated from an exact fresh 37/37 proof. Raw lab evidence remains private and is not part of this customer-shareable package.